

KORA

From Prototype to Enterprise-Ready AI Platform

A roadmap for scaling, securing, and evaluating KORA in a real enterprise environment



Scale • Secure • Retrieve • Evaluate • Improve

Where KORA Stands Today

A working prototype that proves the concept — built for a real production upgrade path

PROTOTYPE, BY DESIGN

- **Synthetic data**

Knowledge base and employee data are simulated, not live enterprise sources.

- **Lightweight retrieval**

Keyword-based lookup, not a production vector-search pipeline.

- **No enterprise IAM**

RBAC is basic role logic, not SSO-backed identity.

- **Heuristic confidence**

An interpretable score, not a statistically calibrated one.

CURRENT REQUEST FLOW

1

User Request



2

Agent Planner



3

RBAC + RAG (lightweight)



4

Gemini (LLM)



5

Verification



6

Output

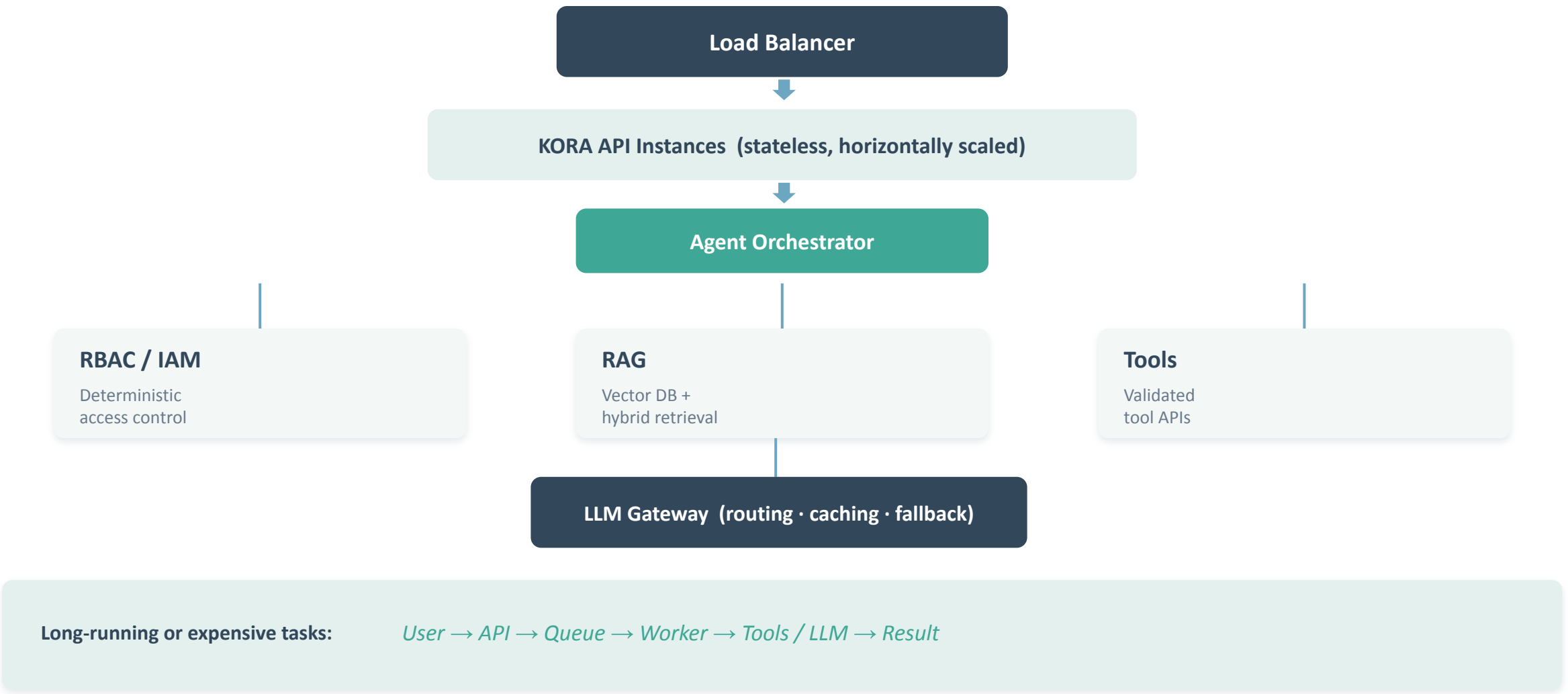
The Path to Production

Every prototype limitation maps to a concrete, well-understood upgrade

PROTOTYPE		PRODUCTION
Synthetic knowledge base	➡	PostgreSQL + object storage
Lightweight retrieval	➡	Embeddings + vector database (pgvector)
Basic RBAC	➡	Enterprise SSO / IAM
In-memory state	➡	Redis / persistent databases
Single backend	➡	Stateless, horizontally scalable services
Basic audit logger	➡	Centralized, immutable audit logs
Direct LLM calls	➡	LLM gateway + model routing
Prototype verification	➡	Evaluation + monitoring pipeline

Scaling the Architecture

Stateless services behind a load balancer, with async workers for expensive tasks



Production-Grade Retrieval

A real ingestion and hybrid-search pipeline, with permissions enforced before the LLM ever sees content



CHUNK METADATA

```
documentId: finance-policy-v3.1  
department: finance  
version: 3.1  
effectiveFrom: 2026-01-01  
accessLevel: FINANCE_ONLY
```

WHY IT MATTERS

KORA's existing temporal conflict-resolution layer decides which policy version is currently valid — so the vector DB handles semantic recall, while KORA's orchestration layer still owns permissions, versioning, and verification.

Security as a Deterministic Layer

The LLM interprets intent. It never makes the final access-control decision.

1

SSO / OAuth

Enterprise identity, not app-level login

2

RBAC / ABAC

Role- and attribute-based authorization

3

Document ACLs

Access enforced before retrieval, not after

4

Encryption

At rest and in transit, end to end

5

Secrets management

No credentials in code or prompts

6

Prompt-injection detection

Untrusted content never grants access

“That’s a security boundary — I’d keep authorization deterministic. The LLM can interpret intent, but it should never make the final access-control decision.”

Reliability & Cost Efficiency

Keep the system available under load, and keep every unnecessary token out of the prompt

RELIABILITY

- Retries with exponential backoff
- Per-call timeouts
- Fallback models on failure
- Circuit breakers
- Response caching
- Graceful degradation

COST EFFICIENCY

- Better retrieval + reranking
- Context compression
- Cache frequent queries
- Batch processing for reports
- Model routing by task complexity

MODEL ROUTING

- | | |
|------------------|-------------------|
| Simple FAQ | ➡ Small model |
| Policy reasoning | ➡ Stronger model |
| Multi-step task | ➡ Strongest model |

Evaluation & Observability

Responses looking good isn't enough — measure the system against a real evaluation dataset

1

Retrieval Recall

2

Context Precision

3

Answer Groundedness

4

Citation Accuracy

5

Authorization Accuracy

6

Conflict Resolution Accuracy

7

Latency

8

Cost / Request

If I Had Another Month

Three priorities, in order — each one builds on the last

01

Retrieval Foundation

Production-grade retrieval with embeddings, hybrid search, and document-level ACLs.

02

Evaluation & Observability

Measure retrieval quality, groundedness, authorization accuracy, latency, and cost.

03

Security & Deployment

Enterprise SSO, persistent audit logs, secrets management, scalable services.

The One-Line Pitch

Separate KORA into scalable services, replace the prototype's in-memory layer with a production database and vector store, integrate enterprise SSO and deterministic authorization, add document-level ACL filtering, introduce an LLM gateway for routing and fallbacks, move long-running tasks to async workers, and add centralized audit logs — all measured by a continuous evaluation pipeline.

The LLM stays responsible for language and reasoning. Security-critical decisions stay deterministic.

Thank you